

DICOM/PACS

Penetration Test Report

Complete Assessment: TEST-001 through TEST-035

Authorized Isolated Homelab Security Assessment

Environment: DICOM.homelab

Assessment period: July - September 2026

Assessment completion date: 28 September 2026

PUBLIC SANITIZED PORTFOLIO VERSION

Exact endpoint addresses and selected infrastructure identifiers have been replaced with role-based labels. No production systems or external targets were included. Synthetic DICOM data was used for controlled write-path testing.

Contents

- 1. Executive Summary** - Overall posture, risk distribution, priority actions
- 2. Scope & Objectives** - Systems, safety constraints, assessment objectives
- 3. Environment Overview** - VLANs, assets, services, clinical workflow
- 4. Tools & Methodology** - Approach, evidence preservation, risk rating
- 5. Consolidated Findings** - 18 consolidated findings from TEST-001 through TEST-035
- 6. Verified Controls & Positive Results** - Controls that operated as intended
- 7. Remediation Roadmap** - Prioritized corrective actions
- 8. Complete Test Matrix - TEST-001 through TEST-035** - Every executed test and outcome
- 9. Evidence Index & Assessment Limitations** - Evidence package references and limitations
- 10. Conclusion** - Overall security posture and next steps

Report construction note: findings are consolidated so repeated validation of the same root cause does not artificially inflate the vulnerability count.

Public sanitization note: exact endpoint IP addresses are intentionally omitted from this portfolio copy; VLAN subnet ranges are retained to demonstrate segmentation design.

1. Executive Summary

An authorized penetration test was performed against an isolated DICOM/PACS homelab designed to emulate a segmented healthcare imaging environment. The complete assessment covered TEST-001 through TEST-035 and evaluated Orthanc PACS, DICOM protocol controls, the DCMTK modality simulator, Mirth Connect, Proxmox VE, Active Directory, Linux host security, backup/recovery controls, network segmentation, logging, time synchronization, and evidence integrity.

The most significant risk is concentrated at the PACS trust boundary. Orthanc management/API access was available without authentication, application-layer management traffic used plaintext HTTP, DICOM transport lacked TLS, an unregistered AE could inject DICOM objects, and a registered AE Title could be spoofed from another host when network reachability was intentionally provided for testing. These weaknesses could affect confidentiality and integrity in a production imaging environment.

The environment also demonstrated strong compensating controls. VLAN policy blocked the Pentest VLAN from protected internal services after temporary testing exceptions were removed; registered/unregistered DICOM behavior correctly protected C-FIND, C-GET, and C-MOVE; SSH administrative access was segmented; malformed DICOM association testing did not destabilize the PACS listener; and final evidence manifests verified successfully with SHA-256.

Overall Risk Summary

Severity	Open Findings	Primary Themes	Priority
High	7	Unauthenticated PACS control plane; plaintext HTTP/DICOM; unauthorized C-STORE; AE spoofing	Immediate
Medium	6 open + 1 remediated	SSH exposure, encryption at rest, backup/recovery, password controls, audit visibility, time sync	Near term
Low	4	Patch/ESM coverage, host firewall, Mirth certificate hygiene, Proxmox MFA/delegation	Planned

Highest-Priority Findings

- Orthanc REST/API access permitted unauthenticated read, download, object creation/deletion, and modality configuration changes.
- Orthanc TCP/8042 used plaintext HTTP and DICOM TCP/4242 used plaintext DICOM; synthetic identifiers were recoverable from captures.
- Unregistered DICOM AE ROGUEAE successfully performed C-STORE and the injected synthetic object persisted.
- Kali KALI_HOST successfully impersonated the registered DCMTK AE Title after a narrow test-only firewall exception allowed TCP/4242 reachability.
- DCMTK host storage and underlying Proxmox storage showed no verified host-level encryption at rest.
- Backup/recovery controls had stale/manual backup characteristics, locally readable backup material, and no full restore validation during the test.

Key Positive Controls

- Called AE Title validation rejected incorrect destination AE Titles.

- Unregistered ROGUEAE was denied C-FIND, C-GET, and C-MOVE while the registered DCMTK modality succeeded.
- Inter-VLAN policy allowed required clinical paths while blocking Proxmox management, Pentest VLAN access, and direct Internet egress from DCMTK.
- TEST-023 malformed/invalid DICOM association probes did not prevent a valid post-test C-ECHO from succeeding.
- Proxmox management TLS supported modern protocol versions and certificate validation in the later management review.
- Time synchronization was remediated during the engagement using OPNsense as the approved internal NTP source.
- TEST-035 verified final evidence manifests with SHA-256.

2. Scope & Objectives

The assessment was limited to systems owned and controlled within DICOM.homelab. No production healthcare systems, third-party networks, or real patient data were targeted.

In-Scope Systems

System	Address / Segment	Role	Key Services / Controls Tested
Proxmox VE	PROXMOX_HOST	Virtualization / management	8006/TLS, SSH, storage, backup, local auth, logging
OPNsense	10.10.x.1 gateways	Firewall / segmentation / NTP	Inter-VLAN policy, state handling, internal NTP
HOSP-AD	AD_HOST	Active Directory / DNS	Password policy, lockout, time, Windows audit
Radiology Workstation / Orthanc	ORTHANC_HOST	PACS / DICOM SCP	8042 HTTP/API, 4242 DICOM, authorization, logs
DCMTK Station	DCMTK_HOST	Modality simulator / DICOM client	SSH 22, receiver 11112, host hardening, C-ECHO/FIND/GET/MOVE/STORE
Mirth Connect	MIRTH_HOST	HL7 interface engine	8443 management, 6662/6663 HL7 paths, TLS/certificate, logs
Kali Attack VM	KALI_HOST	Pentest workstation	Segmentation and adversarial DICOM tests

Assessment Objectives

- Validate PACS management/API authentication and authorization.
- Validate DICOM calling/called AE controls and query/retrieve/store behavior.
- Evaluate cleartext transport exposure and TLS capability for management and DICOM services.
- Assess host exposure, SSH hardening, file permissions, privilege boundaries, patch status, logging, local secret exposure, and encryption at rest.
- Review backup/recovery security and recoverability indicators.
- Validate least-privilege inter-VLAN connectivity and external egress controls.
- Review password/account-lockout, logging/audit, certificate, time synchronization, and privileged administration controls.
- Confirm post-test segmentation restoration and evidence integrity.

Rules of Engagement / Safety Constraints

- Testing was authorized and confined to the isolated lab.
- No production PHI was used; synthetic DICOM identifiers and objects were used for write-path testing.
- No destructive modification or deletion of legitimate studies was performed.
- No password spraying, brute-force campaigns, or intentional account lockouts were performed.
- Temporary firewall exceptions were narrowly scoped, disabled after testing, and followed by segmentation validation.
- Evidence was stored in per-test directories and integrity-protected with SHA-256 manifests where available.

3. Environment Overview

The lab uses OPNsense-controlled VLAN segmentation to emulate separation between infrastructure, clinical imaging, HL7/application, and penetration-testing functions. Orthanc runs on the Radiology Workstation in the Clinical VLAN; DCMTK acts as the modality simulator; Mirth provides HL7 integration; Active Directory provides domain services; and Proxmox hosts the virtual environment.

Segment	Subnet / Representative Hosts	Purpose
Management	10.10.10.0/24 - Proxmox PROXMOX_HOST	Virtualization and management
VLAN 20 - Infrastructure	10.10.20.0/24 - HOSP-AD AD_HOST	AD, DNS, infrastructure
VLAN 30 - Clinical	10.10.30.0/24 - Orthanc ORTHANC_HOST; DCMTK DCMTK_HOST	PACS, modality simulation, DICOM workflow
VLAN 40 - Applications / HL7	10.10.40.0/24 - Mirth MIRTH_HOST	HL7 integration / management
VLAN 50 - Pentest	10.10.50.0/24 - Kali KALI_HOST	Adversarial security testing

Clinical / Imaging Workflow Under Test

The core imaging path consisted of DCMTK communicating with Orthanc over DICOM TCP/4242. Query/retrieve operations included C-ECHO, C-FIND, C-GET, C-MOVE, and C-STORE. A DCMTK storescp receiver on TCP/11112 was used for authorized C-MOVE validation. Mirth supplied HL7 connectivity on TCP/6662 and 6663, with management on TCP/8443.

Trust-Boundary Design Intent

- Pentest VLAN should not directly reach protected internal services under normal policy.
- DCMTK should reach Orthanc DICOM but should not reach Proxmox management or unrestricted Internet services.
- Only required HL7 application ports should be allowed between clinical and Mirth segments.
- DICOM application authorization should distinguish registered modalities from rogue AE Titles.

4. Tools & Methodology

Testing followed an incremental, evidence-preserving workflow. Each control was baselined, exercised with an authorized positive case, challenged with a negative/adversarial case where appropriate, and then documented. Evidence packages were retained with command output, packet captures, configuration excerpts, synthetic DICOM objects, and SHA-256 manifests.

Tools Used

- DCMTK: echoscu, storescu, findscu, getsu, movescu, storescp, dcmdump, dcmodify.
- curl, OpenSSL, netcat, Nmap, tcpdump/Wireshark, Linux networking and host-hardening utilities.
- Windows PowerShell, Active Directory cmdlets, w32tm, auditpol, Get-WinEvent.
- OPNsense firewall rules/logs/states and internal NTP services.
- Proxmox VE command-line tooling, storage/backup utilities, and journal review.
- SHA-256 utilities for evidence integrity validation.

Risk Rating Approach

Rating	Interpretation	Treatment
High	Direct unauthorized access, modification, or exposure of PACS/DICOM data or trust controls.	Prioritize remediation
Medium	Material weakening of defense, auditability, credential controls, recovery, or confidentiality at rest.	Remediate near term
Low	Hardening/hygiene gap with limited direct exploitability in the current segmented design.	Planned improvement

Consolidation rule: repeated tests that validate the same root cause are mapped to one finding where appropriate. For example, multiple plaintext DICOM tests map to a single transport-encryption finding.

5. Consolidated Findings

5.1 Findings Summary

ID	Finding	Severity	Status	Primary Test(s)
F-01	Unauthenticated Orthanc REST API read/download access	High	Open	001, 007, 026
F-02	Unauthenticated DICOM object creation/deletion via REST API	High	Open	002
F-03	Unauthenticated Orthanc modality configuration modification	High	Open	010
F-04	Orthanc management/API traffic uses plaintext HTTP	High	Open	011, 025
F-05	DICOM transport is unencrypted	High	Open	005, 006, 029
F-06	Unregistered DICOM AE can inject objects with C-STORE	High	Open	009, 032
F-07	Registered AE Title can be spoofed from another host	High	Open	033
F-08	DCMTK SSH broadly exposed without host-based source restriction	Medium	Open	012
F-09	Sensitive lab storage lacks verified encryption at rest	Medium	Open	018
F-10	Backup and recovery controls are insufficient	Medium	Open	019
F-11	Weak Active Directory password policy	Medium	Open	027
F-12	Weak local Linux password/lockout controls	Medium	Open	027
F-13	Insufficient end-to-end security audit visibility	Medium	Open	016, 028
F-14	Time synchronization and audit timestamp integrity	Medium	Remediated	024
F-15	DCMTK security updates unavailable without ESM Apps	Low	Open	015
F-16	DCMTK host firewall not enforcing inbound source restrictions	Low	Open	021
F-17	Mirth management certificate requires hardening	Low	Open	025

ID	Finding	Severity	Status	Primary Test(s)
F-18	Proxmox privileged administration lacks TFA/delegation	Low	Open	026

F-01 - Unauthenticated Orthanc REST API Read/Download Access

Severity	Status	Affected System(s)	Test Reference(s)
High	Open	Orthanc PACS - ORTHANC_HOST:8042	TEST-001, TEST-007, TEST-026

Description

Orthanc REST resources were accessible without authentication. Early testing confirmed unauthenticated retrieval of system/study/patient data, and a later dedicated download test demonstrated unauthenticated DICOM retrieval. TEST-026 reconfirmed that authentication was disabled while remote access remained enabled.

Evidence

- Unauthenticated GET requests to Orthanc REST resources returned HTTP 200 and metadata.
- Unauthenticated DICOM instance download succeeded during TEST-007 and the downloaded object was validated.
- TEST-026 configuration corroboration identified AuthenticationEnabled=false and RemoteAccessAllowed=true.

Impact

Any host that can reach TCP/8042 can enumerate and retrieve PACS information without an identity challenge. In production, this could expose PHI and greatly increase the impact of an internal foothold or segmentation bypass.

Recommendations

- Enable Orthanc authentication for REST/API and administrative access.
- Restrict TCP/8042 to explicitly authorized management systems.
- Use individually attributable accounts and retain auditable access logs.

F-02 - Unauthenticated DICOM Object Creation/Deletion via REST API

Severity	Status	Affected System(s)	Test Reference(s)
High	Open	Orthanc PACS REST API	TEST-002

Description

An unauthenticated client successfully used Orthanc REST functionality to create a synthetic DICOM object, retrieve it, and delete it. Cleanup verification confirmed the synthetic object was removed after the test.

Evidence

- POST to the controlled DICOM creation path returned success for a synthetic object.
- Unauthenticated follow-up retrieval validated the object existed.
- Unauthenticated DELETE succeeded; a subsequent request returned 404, confirming cleanup.

Impact

Unauthenticated write/delete capability threatens PACS data integrity and availability. A malicious internal client could insert false imaging records or remove data if network reachability is obtained.

Recommendations

- Require authentication for all write/delete REST operations.
- Restrict management/API reachability with host-based and network-layer allowlists.

- Review Orthanc authorization controls and log all destructive API actions.

F-03 - Unauthenticated Orthanc Modality Configuration Modification

Severity	Status	Affected System(s)	Test Reference(s)
High	Open	Orthanc PACS modality configuration	TEST-010

Description

An unauthenticated client could create, read, modify, and delete a temporary Orthanc modality configuration entry through the REST API. The temporary test modality was removed and final verification confirmed it was no longer present.

Evidence

- Unauthenticated PUT created a temporary modality named PENTEST-TEMP-010.
- Subsequent unauthenticated retrieval verified the configuration change.
- Unauthenticated DELETE removed the temporary entry; final modality inventory reported it absent.

Impact

Unauthorized modality configuration changes can redirect DICOM workflows, create attacker-controlled destinations, or facilitate data exfiltration and trust-boundary bypass.

Recommendations

- Enable Orthanc REST authentication and restrict configuration endpoints to administrators.
- Restrict TCP/8042 to authorized management hosts.
- Audit modality add/change/delete actions and periodically review the configured modality inventory.

F-04 - Orthanc Management/API Traffic Uses Plaintext HTTP

Severity	Status	Affected System(s)	Test Reference(s)
High	Open	Orthanc PACS - ORTHANC_HOST:8042	TEST-011, TEST-025

Description

Orthanc management/API traffic was served over plaintext HTTP. A controlled synthetic REST transaction was captured in cleartext, HTTPS negotiation failed on the same listener, and later management TLS testing again confirmed the endpoint was not secure.

Evidence

- TEST-011 captured synthetic REST/API data over plaintext HTTP; IsHttpServerSecure was false.
- HTTPS/TLS probes against TCP/8042 failed while HTTP requests succeeded.
- TEST-025 independently reconfirmed plaintext management transport.

Impact

Management/API requests and responses are visible to systems with network-path visibility. If authentication is later enabled without TLS, credentials and session material could also be exposed.

Recommendations

- Protect Orthanc management with HTTPS natively or behind a TLS reverse proxy.
- Use an internally trusted certificate with the intended management hostname in SAN.
- Keep TCP/8042 restricted to approved administrative clients.

F-05 - DICOM Transport Is Unencrypted

Severity	Status	Affected System(s)	Test Reference(s)
High	Open	Orthanc PACS - TCP/4242	TEST-005, TEST-006, TEST-029

Description

Orthanc accepted plaintext DICOM while DICOM TLS was unavailable/disabled. Repeated controlled captures demonstrated that synthetic DICOM identifiers could be recovered directly from network traffic without decryption.

Evidence

- TEST-005 TLS capability probing showed no successful DICOM TLS negotiation while plaintext C-ECHO worked.
- TEST-006 plaintext C-STORE PCAP exposed PENTEST^PLAINTEXT and PENTEST-TLS-001.
- TEST-029 reconfirmed DicomTlsEnabled=false, successful plaintext DICOM, recoverable synthetic identifiers, and failed TLS-enabled C-ECHO.

Impact

Network observers can inspect DICOM metadata and potentially image content in transit. In production this may expose PHI and weakens resistance to interception or manipulation.

Recommendations

- Enable DICOM TLS where supported and configure trusted certificates/CA validation.
- Prefer mutual TLS for trusted modality relationships where feasible.
- Preserve segmentation as defense in depth rather than relying on it as the only confidentiality control.

F-06 - Unregistered DICOM AE Can Inject Objects With C-STORE

Severity	Status	Affected System(s)	Test Reference(s)
High	Open	Orthanc PACS - DICOM C-STORE	TEST-009, TEST-032

Description

Orthanc accepted C-STORE from an unregistered calling AE Title. TEST-009 first demonstrated rogue C-STORE success, and TEST-032 independently reproduced the condition and verified that the rogue synthetic object persisted in the PACS.

Evidence

- TEST-009 ROGUE AE association was accepted and Store Response returned Success.
- TEST-032 ROGUEAE C-STORE succeeded from an unregistered AE.
- Follow-up C-FIND verified PatientName PENTEST^ROGUE_STORE and PatientID TEST032-ROGUE persisted.
- Configuration behavior was consistent with DicomAlwaysAllowStore=true.

Impact

An unauthorized system with DICOM reachability can inject spoofed or misleading imaging objects, threatening PACS integrity and downstream clinical workflow trust.

Recommendations

- Set DicomAlwaysAllowStore=false.
- Explicitly register only required C-STORE modalities and restrict TCP/4242 by source.
- Retest to confirm registered C-STORE succeeds and unregistered C-STORE is rejected.

F-07 - Registered AE Title Can Be Spoofed From Another Host

Severity	Status	Affected System(s)	Test Reference(s)
High	Open	Orthanc modality trust model	TEST-033

Description

A Kali host on KALI_HOST was initially blocked by segmentation. After a narrowly scoped temporary rule allowed only Kali to Orthanc TCP/4242, the same Kali host was denied C-FIND as ROGUEAE but succeeded when it changed only its calling AE Title to the registered DCMTK value, whose configured host was DCMTK_HOST.

Evidence

- ROGUEAE from Kali was denied/aborted.
- Spoofed DCMTK from the same Kali source succeeded and returned the synthetic TEST032-ROGUE study.
- Temporary firewall access was disabled and post-test TCP/4242 segmentation timed out.

Impact

AE Titles are identifiers rather than strong authentication. A host that can reach the service may impersonate a trusted modality and inherit its permissions.

Recommendations

- Do not rely on AE Title alone for identity assurance.
- Maintain strict source-host firewall allowlists for DICOM.
- Add DICOM TLS with certificate validation where supported.
- Periodically review and remove stale modality definitions.

F-08 - DCMTK SSH Broadly Exposed Without Host-Based Source Restriction

Severity	Status	Affected System(s)	Test Reference(s)
Medium	Open	DCMTK Station - DCMTK_HOST:22	TEST-012

Description

The DCMTK Station exposed OpenSSH on all IPv4 and IPv6 interfaces. Password authentication was enabled and no host firewall or explicit SSH source restriction was active at the host. SSH was reachable from the Radiology Workstation and Proxmox, while the Pentest VLAN was blocked upstream.

Evidence

- sshd listened on 0.0.0.0:22 and [::]:22.
- PasswordAuthentication=yes; PubkeyAuthentication=yes; PermitRootLogin=without-password.
- UFW inactive; nftables absent; iptables default INPUT/FORWARD/OUTPUT policies ACCEPT.
- TCP/22 reachable from authorized internal paths; upstream segmentation blocked Kali.

Impact

If upstream segmentation is weakened or bypassed, a broad SSH listener with password authentication increases the remote credential-attack surface and lateral-movement options.

Recommendations

- Restrict SSH at the host to approved management source addresses where practical.
- Prefer public-key authentication and disable password authentication after validating access recovery.
- Retain upstream VLAN controls as a second layer.

F-09 - Sensitive Lab Storage Lacks Verified Encryption at Rest

Severity	Status	Affected System(s)	Test Reference(s)
Medium	Open	DCMTK VM / Proxmox storage	TEST-018

Description

Testing did not identify host-level encryption for the DCMTK VM or its Proxmox-backed storage. The VM used LVM-thin storage backed by the Proxmox NVMe/LVM stack; no active LUKS/crypttab or ZFS encryption was verified.

Evidence

- DCMTK root storage mapped through LVM without an identified active dm-crypt/LUKS layer.
- Proxmox local/local-lvm storage review did not identify active crypttab entries or ZFS encryption.
- VM 104 disk was stored on Proxmox LVM-thin backed by /dev/nvme0n1p3.
- Hardware/self-encrypting drive protection was not verified.

Impact

Offline access to host storage, stolen media, or lower-level storage compromise could expose retained DICOM/PACS lab data and evidence without cryptographic protection.

Recommendations

- Use supported full-disk or storage-layer encryption for systems that retain sensitive imaging/evidence.
- Document key management and recovery procedures.
- Verify backup media encryption separately from primary storage encryption.

F-10 - Backup and Recovery Controls Are Insufficient

Severity	Status	Affected System(s)	Test Reference(s)
Medium	Open	Proxmox / DCMTK VM backups	TEST-019

Description

Backup/recovery review identified a readable local backup archive, no current scheduled backup job in the reviewed configuration, and a stale identified recovery point. Archive integrity could be checked, but a complete restore was not performed during the assessment.

Evidence

- DCMTK VM backup material was readable by an unprivileged local user; archive mode observed as 0644 with directory mode 0755.
- No current scheduled backup job was identified in the reviewed /etc/pve/jobs.cfg / cluster backup configuration.
- Newest identified VM 104 backup was dated 2026-01-14.
- zstd integrity validation succeeded; prior backup log showed Finished Backup of VM 104.
- Local storage utilization was approximately 92.75%, reducing recovery headroom.
- A full restoration test was not completed.

Impact

Backups that are broadly readable, stale, unscheduled, or untested can fail to provide dependable recovery and may expose sensitive VM contents to local users.

Recommendations

- Restrict backup archive permissions and storage access.
- Create and monitor scheduled backups with defined retention and recovery-point objectives.
- Maintain adequate free capacity or use dedicated backup storage.
- Perform periodic isolated restore tests and record recovery evidence.

F-11 - Weak Active Directory Password Policy

Severity	Status	Affected System(s)	Test Reference(s)
Medium	Open	HOSP-AD - AD_HOST	TEST-027

Description

The domain had complexity and lockout controls but allowed a minimum password length of 0, no password history, minimum password age 0, and the built-in Administrator account with PasswordNeverExpires=True.

Evidence

- ComplexityEnabled=True.
- MinPasswordLength=0; PasswordHistoryCount=0; MinPasswordAge=0 days.
- LockoutThreshold=10; duration/observation window 10 minutes.
- Built-in Administrator was enabled with PasswordNeverExpires=True.

Impact

Weak or reused privileged credentials may remain valid for extended periods and reduce resistance to credential compromise.

Recommendations

- Adopt a stronger minimum password/passphrase length based on organizational policy.
- Enable password history and appropriate privileged-account controls.
- Review PasswordNeverExpires on administrative accounts and add MFA where supported.

F-12 - Weak Local Linux Password and Account Lockout Controls

Severity	Status	Affected System(s)	Test Reference(s)
Medium	Open	Proxmox, Mirth host, DCMTK host	TEST-027

Description

Reviewed Linux administrative hosts used effectively non-expiring local passwords and did not show clearly enforced pam_pwquality, pam_pwhistory, or pam_faillock policy in the reviewed stack.

Evidence

- PASS_MAX_DAYS=99999 and PASS_MIN_DAYS=0 on reviewed hosts.
- Privileged/local accounts reported password expiration as never.
- No clear pam_pwquality, pam_pwhistory, or pam_faillock enforcement was identified.

Impact

Compromised local administrative credentials may remain usable for long periods, while the absence of explicit failed-login controls may permit repeated attempts against reachable services.

Recommendations

- Implement an appropriate PAM baseline for privileged local accounts.
- Use strong passphrases, suitable aging/history controls, and failed-login throttling/lockout.
- Prefer SSH public-key authentication and MFA/TFA where supported.

F-13 - Insufficient End-to-End Security Audit Visibility

Severity	Status	Affected System(s)	Test Reference(s)
Medium	Open	Orthanc primarily; supporting systems	TEST-016, TEST-028

Description

Core infrastructure logging was present and controlled failed SSH activity was captured, but security-relevant PACS/API and administrative actions were not consistently attributable across the environment. Some hosts also lacked enhanced audit tooling.

Evidence

- TEST-016: journald/rsyslog active and persistent; SSH/sudo events recorded; controlled failed SSH event appeared in auth.log and bttmp.
- auditd and fail2ban were not installed/active on the reviewed DCMTK host.
- TEST-028: Orthanc startup/security configuration was logged, but controlled REST/C-ECHO activity was not clearly attributable at the current logging level.
- Mirth, Windows Security, and Linux retention/visibility each had hardening gaps noted during review.

Impact

Incomplete attribution and retention can hinder detection, incident response, and forensic reconstruction of PACS or administrative activity.

Recommendations

- Increase Orthanc audit visibility for source, AE Title, API operation, identity, and success/failure.
- Forward critical logs to centralized monitoring where practical.
- Increase Windows Security log retention or forward off-host.
- Consider auditd/equivalent on critical Linux systems without capturing unnecessary PHI or credentials.

F-14 - Time Synchronization and Audit Timestamp Integrity

Severity	Status	Affected System(s)	Test Reference(s)
Medium	Remediated	HOSP-AD, Orthanc workstation, DCMTK, Mirth, Proxmox	TEST-024

Description

Time synchronization was initially inconsistent across the lab. During the assessment, OPNsense was validated as the internal NTP source and affected systems were reconfigured and successfully synchronized.

Evidence

- HOSP-AD changed from Local CMOS Clock to OPNsense VLAN20_GATEWAY.
- Orthanc/Radiology workstation continued through the AD hierarchy.
- DCMTK synchronized to VLAN30_GATEWAY; Mirth to VLAN40_GATEWAY.
- Proxmox Chrony selected VLAN10_GATEWAY with normal leap status.

Impact

Before remediation, timestamp drift could undermine cross-system log correlation and forensic timelines. The issue was corrected during the engagement.

Recommendations

- Maintain OPNsense as the approved internal NTP source.
- Periodically verify synchronization health and alert on loss of sync or excessive offset.

F-15 - DCMTK Security Updates Unavailable Without ESM Apps

Severity	Status	Affected System(s)	Test Reference(s)
Low	Open	DCMTK Station	TEST-015

Description

The DCMTK host was generally current and unattended-upgrades was active, but two DCMTK-related security updates were in pending_attach state because Ubuntu Pro/ESM Apps coverage was not enabled. A separate fwupd update was phased/deferred and treated as maintenance rather than a security finding.

Evidence

- Ubuntu 24.04.4 LTS; DCMTK 3.6.7-9.1build4.
- Pending ESM updates affected dcmk and libdcmk17t64, with fixed version 3.6.7-9.1ubuntu0.1~esm1.
- Associated upstream issues included CVE-2024-34508 and CVE-2024-34509.
- Unattended-upgrades was enabled/active and no reboot was pending.

Impact

Known package fixes may remain unavailable, leaving vulnerabilities unpatched. Current exploitability was reduced because TCP/11112 was not persistently exposed.

Recommendations

- Enable an appropriate supported repository/ESM entitlement or move to package versions with available security fixes.
- Continue automatic security updates and periodic patch-status review.

F-16 - DCMTK Host Firewall Not Enforcing Inbound Source Restrictions

Severity	Status	Affected System(s)	Test Reference(s)
Low	Open	DCMTK Station	TEST-021

Description

The DCMTK host relied on upstream segmentation rather than an active host firewall. UFW was inactive, nftables had no enforcing rules, and iptables default policies were ACCEPT. Only SSH and local resolver listeners were exposed at the time of the full service review, limiting immediate impact.

Evidence

- UFW status: inactive.
- nftables ruleset did not provide an enforcing policy.
- iptables INPUT/FORWARD/OUTPUT default policies were ACCEPT.
- Upstream OPNsense segmentation filtered Kali/Pentest access, providing a compensating control.

Impact

Loss or misordering of upstream firewall controls could expose host services without a second enforcement layer.

Recommendations

- Enable a host firewall with default-deny inbound policy and explicit administrative/DICOM allowances.
- Restrict SSH to approved management sources.
- Document required local exceptions and validate them after changes.

F-17 - Mirth Management Certificate Requires Hardening

Severity	Status	Affected System(s)	Test Reference(s)
Low	Open	Mirth Connect - MIRTH_HOST:8443	TEST-025

Description

Mirth provided encrypted TLS 1.2 transport and rejected obsolete TLS 1.0/1.1, but the management certificate lacked a SAN, used CN=mirth-connect rather than the intended hostname, was not trusted by the tested client trust store, and had an unusually long validity period.

Evidence

- TLS 1.2 supported; TLS 1.0/1.1 disabled.
- Certificate SAN absent; subject CN=mirth-connect.
- Issuer was Mirth Connect Certificate Authority and validation was not trusted by the tested client.
- Validity extended approximately 50 years.

Impact

Administrators may become conditioned to certificate warnings and cannot strongly validate the intended management hostname.

Recommendations

- Replace the certificate with one issued by the trusted internal CA.
- Include the chosen Mirth management hostname in SAN.
- Use an appropriate certificate lifetime and install the required trust chain.

F-18 - Proxmox Privileged Administration Lacks TFA / Individual Delegation

Severity	Status	Affected System(s)	Test Reference(s)
Low	Open	Proxmox VE	TEST-026

Description

Proxmox required administrative authentication and used strong TLS, but root@pam was the primary observed privileged identity, no TFA was configured for that account, and no explicit delegated groups/ACLs were observed.

Evidence

- Authentication realms pam and pve were present.
- root@pam was the primary observed privileged account.
- No TFA entry was returned for root@pam.
- No explicit delegated groups/ACL entries were observed during review.

Impact

A single highly privileged identity without a second factor increases the impact of credential compromise and reduces individual attribution.

Recommendations

- Enable supported TFA for highly privileged accounts.
- Use individually attributable administrative identities and delegated roles where practical.
- Reserve root@pam for break-glass use where operationally feasible.

6. Verified Controls & Positive Results

Called AE Title Validation - PASS

TEST-004: Incorrect called AE Title was rejected permanently with Called AE Title Not Recognized; correct ORTHANC baseline succeeded.

Registered vs Rogue C-ECHO / C-FIND Controls - PASS

TEST-003, TEST-008: Registered DCMTK operations succeeded while rogue calling AE behavior was denied/aborted for protected operations.

Sensitive File Permission Boundary - PASS

TEST-013: No world-writable files were found; sampled sensitive evidence was not readable by an unprivileged account because of parent-directory restrictions; .ssh and authorized_keys permissions were appropriately restrictive.

Local Privilege Baseline - PASS

TEST-014: No user-writable capability-bearing files, concerning writable PATH/cron targets, or writable enabled systemd units were identified. Full sudo for ttech was treated as intentional administration.

Local Secret Exposure Review - PASS

TEST-017: Initial heuristic history hits were re-reviewed with a safer classifier; no strict inline secret pattern was confirmed, no overexposed private keys were found, and no secret-bearing configuration entries were identified.

SSH Network Segmentation - PASS

TEST-020: Proxmox-to-DCMTK SSH was reachable as an authorized administrative path while Kali/Pentest VLAN TCP/22 was filtered/timed out; .ssh=0700 and authorized_keys=0600.

Inter-VLAN Egress Controls - PASS

TEST-022: DCMTK Internet egress and Proxmox management access were blocked; required Orthanc DICOM and intended Mirth HL7 paths were allowed; Kali/Pentest path remained blocked.

DICOM Association Robustness - PASS

TEST-023: Invalid called AE was rejected, invalid calling AE was aborted, malformed raw input did not destabilize the listener, and a valid post-test C-ECHO still succeeded.

DICOM Query/Retrieve Authorization - PASS

TEST-030: Registered DCMTK C-FIND/C-GET succeeded; ROGUEAE was denied and retrieved zero files.

DICOM C-MOVE Authorization - PASS

TEST-031: Registered DCMTK C-MOVE to STORESCP succeeded; rogue move was denied and produced zero files.

Final Network Segmentation - PASS

TEST-034: Kali could not reach Orthanc 4242/8042, DCMTK 22/11112, Mirth 8443/6662, or HOSP-AD 389/445 after the temporary TEST-033 rule was disabled; Internet access remained available.

Evidence Integrity - PASS

TEST-035: Reviewed TEST-029 through TEST-034 evidence manifests verified successfully with SHA-256; no integrity failures identified in the final phase.

7. Remediation Roadmap

Remediation should first eliminate unauthenticated PACS control-plane access and transport weaknesses, then harden host/recovery controls and monitoring. The existing segmentation model should be preserved throughout remediation.

Priority	Action	Related Findings	Validation Criteria
1 - Immediate	Enable Orthanc authentication; restrict 8042; separate administrative access from clinical data paths.	F-01, F-02, F-03	Unauthenticated reads/writes/config changes return 401/403; authorized admin workflow remains functional.
2 - Immediate	Enable HTTPS for Orthanc management and DICOM TLS where supported.	F-04, F-05	TLS validates to internal CA; plaintext management disabled; DICOM TLS succeeds with approved peers.
3 - Immediate	Set DicomAlwaysAllowStore=false and combine AE registration with source-host/TLS trust.	F-06, F-07	Registered modality stores/queries succeed; rogue and spoofed sources fail.
4 - Near term	Harden DCMTK SSH/host firewall and improve credential policy.	F-08, F-12, F-16	Host firewall default-deny; SSH restricted; strong PAM/lockout controls; keys/TFA where supported.
5 - Near term	Implement encryption at rest and mature backup/recovery.	F-09, F-10	Encrypted primary/backup storage; scheduled monitored backups; successful isolated restore test.
6 - Near term	Improve end-to-end audit visibility and retention.	F-13	Orthanc/Mirth/admin actions are attributable and forwarded/retained appropriately.
7 - Planned	Close patch/certificate/MFA hygiene gaps.	F-15, F-17, F-18	DCMTK security fixes available; Mirth trusted SAN certificate; Proxmox TFA/delegated accounts.
Maintain	Preserve OPNsense segmentation and internal NTP health.	F-14 / positive controls	Time remains synchronized; TEST-034-style segmentation checks continue to pass.

8. Complete Test Matrix - TEST-001 through TEST-035

This matrix includes every test performed in the assessment sequence. PASS with observation means the primary security objective passed but a hardening opportunity was documented. FAIL means a security control weakness was confirmed.

Test	Title	Result	Severity	Key Outcome / Finding Link
TEST-001	Unauthenticated Orthanc REST Read Access	FAIL	High	Unauthenticated PACS REST reads exposed system/study/patient information; foundation of F-01.
TEST-002	Unauthenticated DICOM Object Creation/Deletion via REST API	FAIL	High	Synthetic DICOM object could be created, retrieved, and deleted without authentication; F-02.
TEST-003	AE Title Access Control (C-ECHO)	PASS	-	Known DCMTK AE succeeded; rogue calling AE was aborted/denied for echo behavior.
TEST-004	Called AE Title Validation	PASS	-	Correct ORTHANC called AE succeeded; incorrect called AE was rejected as not recognized.
TEST-005	DICOM Transport / TLS Baseline	FAIL	High	Plain DICOM succeeded while TLS negotiation did not; supports F-05.
TEST-006	Plaintext C-STORE Capture	FAIL	High	Synthetic identifiers recovered from C-STORE PCAP; confirms cleartext DICOM (F-05).
TEST-007	Unauthenticated DICOM Download	FAIL	High	DICOM instance download succeeded without REST authentication; reinforces F-01.
TEST-008	Rogue C-FIND Authorization	PASS	-	Known AE C-FIND succeeded; rogue AE query was aborted/denied.
TEST-009	Rogue C-STORE Authorization	FAIL	High	Unregistered calling AE completed C-STORE successfully; F-06.
TEST-010	Modality Configuration Write	FAIL	High	Unauthenticated temporary modality create/read/delete succeeded; F-03.
TEST-011	Orthanc HTTP Transport Encryption	FAIL	High	REST/API traffic observed over plaintext HTTP; HTTPS probe failed; F-04.
TEST-012	DCMTK Station Host Exposure Baseline	FAIL	Medium	SSH exposed on all interfaces with password auth and no host source restriction; F-08.
TEST-013	Sensitive File Permissions	PASS w/ observation	-	No unauthorized read of sampled sensitive evidence; no world-writable files; group/umask hardening observation.

Test	Title	Result	Severity	Key Outcome / Finding Link
TEST-014	Local Privilege Baseline	PASS w/ observation	-	No unexpected writable privilege-escalation paths; full sudo intentional; password-aging observation.
TEST-015	Patch Status	FAIL	Low	Two DCMTK-related ESM security updates were pending attach; F-15.
TEST-016	Security Logging	PASS w/ observation	-	journald/rsyslog and SSH/sudo logging worked; auditd/fail2ban/retention hardening observations feed F-13.
TEST-017	Local Secret Exposure	PASS	-	No strict secret pattern or overexposed private key confirmed after safe history review.
TEST-018	Data-at-Rest Encryption	FAIL	Medium	No verified LUKS/ZFS/storage encryption for DCMTK VM/Proxmox path; F-09.
TEST-019	Backup and Recovery Security	FAIL	Medium	Backup readability, lack of current schedule, stale recovery point, and no full restore validation; F-10.
TEST-020	SSH Security	PASS w/ observation	-	Authorized Proxmox SSH path allowed; Kali/Pentest blocked; key permissions strong; config hardening opportunities only.
TEST-021	Host Firewall and Exposed Services	FAIL	Low	UFW inactive, no nftables enforcement, iptables default ACCEPT; upstream segmentation compensates; F-16.
TEST-022	Inter-VLAN Egress Controls	PASS	-	DCMTK Internet/Proxmox management blocked; intended Orthanc/Mirth workflow paths allowed; Kali blocked.
TEST-023	DICOM Association Robustness	PASS	-	Invalid AE/malformed input handled without loss of service; post-malformed valid C-ECHO succeeded.
TEST-024	Time Synchronization & Audit Timestamp Integrity	PASS after remediation	Medium (remediated)	OPNsense established as internal NTP; HOSP-AD, Orthanc, DCMTK, Mirth, Proxmox synchronized; F-14.
TEST-025	Management HTTPS & Certificate Security	FAIL	High/Low	Orthanc plaintext HTTP (F-04); Mirth certificate hardening issue (F-17); Proxmox TLS passed.
TEST-026	Administrative Account & Authentication Controls	FAIL	High/Low	Orthanc REST unauthenticated (F-01/F-03); Proxmox auth present but TFA/delegation hardening gap (F-18).
TEST-027	Password Policy & Account Lockout Controls	FAIL	Medium	Weak AD and Linux password/aging/lockout controls; F-11 and F-12.

Test	Title	Result	Severity	Key Outcome / Finding Link
TEST-028	Logging & Audit Coverage	FAIL	Medium	Infrastructure logs present, but PACS/admin attribution and retention gaps remain; F-13.
TEST-029	DICOM Transport Encryption	FAIL	High	DicomTlsEnabled=false; synthetic identifiers recovered from C-STORE PCAP; F-05.
TEST-030	DICOM Query/Retrieve Authorization	PASS	-	Registered DCMTK C-FIND/C-GET succeeded; ROGUEAE denied.
TEST-031	DICOM C-MOVE Authorization	PASS	-	Authorized move succeeded to STORESCP; rogue move denied and produced zero files.
TEST-032	DICOM C-STORE Authorization	FAIL	High	Unregistered ROGUEAE C-STORE succeeded and object persisted; F-06.
TEST-033	AE Title Spoofing / Modality Trust	FAIL	High	Kali spoofing registered DCMTK AE Title inherited C-FIND access when network reachability was temporarily granted; F-07.
TEST-034	Final Network Segmentation Validation	PASS	-	Pentest VLAN blocked from protected services while Internet remained available.
TEST-035	Final Validation / Evidence Integrity	PASS	-	Final-phase SHA-256 manifests verified with no integrity failures.

9. Evidence Index & Assessment Limitations

9.1 Evidence Directory Index

Test	Evidence Package / Directory
TEST-001	Initial Orthanc REST read-access evidence / FINDING-001 package
TEST-002	Initial unauthenticated create/delete evidence / FINDING-002 package
TEST-003	TEST-003-ae-title-control
TEST-004	TEST-004-called-aet-control
TEST-005	TEST-005-dicom-transport
TEST-006	TEST-006-plaintext-cstore
TEST-007	TEST-007-unauthenticated-dicom-download
TEST-008	TEST-008-rogue-cfind
TEST-009	TEST-009-rogue-cstore
TEST-010	TEST-010-modality-config-write
TEST-011	TEST-011-orthanc-http-transport
TEST-012	TEST-012-dcmtk-host-baseline
TEST-013	TEST-013-sensitive-file-permissions
TEST-014	TEST-014-local-privilege-baseline
TEST-015	TEST-015-patch-status
TEST-016	TEST-016-security-logging
TEST-017	TEST-017-local-secret-exposure
TEST-018	TEST-018-data-at-rest-encryption
TEST-019	TEST-019-backup-recovery-security
TEST-020	TEST-020-ssh-security
TEST-021	TEST-021-host-firewall-exposed-services
TEST-022	TEST-022-inter-vlan-egress-controls
TEST-023	TEST-023-dicom-association-robustness
TEST-024	Time-sync remediation package
TEST-025	Management HTTPS / certificate evidence package
TEST-026	Administrative authentication evidence package
TEST-027	Password / lockout evidence package
TEST-028	Logging / audit evidence package
TEST-029	TEST-029-dicom-transport-encryption

Test	Evidence Package / Directory
TEST-030	TEST-030-dicom-query-retrieve-authorization
TEST-031	TEST-031-dicom-cmove-authorization
TEST-032	TEST-032-dicom-cstore-authorization
TEST-033	TEST-033-ae-title-spoofing
TEST-034	TEST-034-network-segmentation
TEST-035	TEST-035-final-validation (distributed Kali/DCMTK validation records)

9.2 Representative Evidence Types

- DCMTK association logs for positive and negative C-ECHO/C-FIND/C-GET/C-MOVE/C-STORE tests.
- Packet captures demonstrating plaintext HTTP and plaintext DICOM synthetic metadata.
- Orthanc REST response headers/bodies and controlled synthetic object records.
- Host configuration outputs for SSH, firewall, permissions, patch status, logging, storage, backup, password policy, and time synchronization.
- OPNsense reachability/segmentation validation from clinical and Pentest VLAN perspectives.
- SHA-256 manifests used to verify final evidence integrity.

9.3 Assessment Limitations

- This was an isolated homelab assessment, not a production clinical penetration test.
- No real PHI or production patient records were used.
- A full backup restoration was not performed during TEST-019; recoverability conclusions are therefore limited to backup availability/integrity indicators and configuration review.
- Hardware self-encrypting-drive status was not verified during TEST-018; the finding concerns the absence of verified host/storage-layer encryption.
- Password spraying, brute force, destructive ransomware behavior, and denial-of-service testing were excluded.
- Temporary TEST-033 network access was intentionally introduced solely to isolate the application-layer AE Title trust question; normal segmentation was restored and validated afterward.
- Severity reflects the tested lab architecture and compensating controls; production severity should be reassessed against real clinical exposure, PHI volume, and organizational controls.

9.4 Evidence Integrity

Final validation verified the available SHA-256 manifests for TEST-029 through TEST-034, including the received TEST-031 DICOM object. All checked entries returned OK. TEST-035 recorded the final validation state and confirmed normal Pentest-VLAN segmentation had been restored.

10. Conclusion

The complete TEST-001 through TEST-035 assessment shows a lab with strong network segmentation and several correctly functioning DICOM authorization controls, but with significant application-layer weaknesses at the Orthanc PACS boundary. The highest priorities are to authenticate and encrypt the Orthanc management plane, enable secure DICOM transport where supported, prevent unregistered C-STORE, and avoid treating AE Title alone as a strong identity control.

Secondary priorities include strengthening DCMTK host defense, encrypting data at rest, maturing backup/restore controls, improving password and audit policy, closing patch/certificate/TFA hardening gaps, and preserving the successful time-synchronization and VLAN-segmentation design. The final post-test validation confirmed the temporary test path was removed and evidence integrity checks passed.

Recommended Retest Exit Criteria

- Unauthenticated Orthanc REST requests are denied and authenticated administrative access uses HTTPS with trusted certificates.
- Plaintext DICOM is disabled or restricted as designed, and DICOM TLS succeeds with approved peers where supported.
- ROGUEAE C-STORE and spoofed-source AE Title tests fail while registered clinical workflows remain functional.
- DCMTK host firewall/SSH rules enforce least privilege without breaking authorized management.
- Primary and backup storage encryption/recovery controls meet documented objectives and a restore test succeeds.
- PACS/API and administrative security events are attributable and retained centrally or for an approved period.
- TEST-034-style segmentation checks and TEST-035-style evidence integrity verification continue to pass.

END OF REPORT